TFG · SONDA PASIVA DE DETECCIÓN PQC · TUTORÍA 3 · TAREA 2

Alert y cierres tras el ClientHello

Qué hace la sonda cuando el servidor no contesta con un ServerHello, y contraste con la prueba activa sobre servidores reales

Pablo Marugán Bastante · GITST, EPS-UAM · Tutor: Jorge E. López de Vergara | **11/11/2026**

1. Conclusión principal

> **RESULTADO**
> La sonda distingue ahora entre un servidor que **rechaza** el handshake (Alert o cierre con FIN/RST) y uno que **no responde**. Si el cliente solo ofrecía PQ, el rechazo demuestra que el servidor no lo soporta. Con un cliente que solo ofrece X25519MLKEM768, como la sonda activa de Roberto, el veredicto pasivo **coincide con el de OpenSSL en los 10 servidores probados**. Es el paso previo para comparar con su batería de pruebas sin mezclar «no responde» con «no soporta».

2. El problema

Al ofrecer un solo grupo PQ a un servidor que no lo soporta, el servidor no responde con un ServerHello. En la prueba activa del 09/11 aparecieron tres respuestas distintas, y la sonda las clasificaba todas como «sin respuesta»:

Respuesta	Ejemplo	Qué es
Alert (registro TLS tipo 21)	wikipedia, github, boe	Va en claro, porque aún no hay claves: nivel (1 byte) y código (1 byte). El 40 es `handshake_failure`: no hay nada en común.
Cierre TCP sin Alert (FIN o RST)	santander.es	El servidor corta sin explicar por qué. OpenSSL lo muestra como «unexpected eof».
Nada	caixabank.es, uam.es (a veces)	No llega a contestar, a veces ni al SYN.

3. Qué hace ahora la sonda (bloque 6)

- Lee el **Alert** del servidor si llega antes del ServerHello y guarda el nivel y el código.
- Detecta el **FIN o RST** del servidor después del ClientHello, si no ha mandado ni ServerHello ni Alert.
- Nuevo estado de conexión: `rechazada`, distinto de `sin_respuesta`.
- JSON: nuevos campos `server_alert` (nivel, código y nombre) y `server_close` (`fin` o `rst`).

Criterio. Un rechazo solo dice algo de PQ si el cliente no le daba otra opción:

Cliente	Servidor	Veredicto del servidor
Solo ofrece grupos PQ	Alert o cierre	**inseguro (rechaza_solo_pq / cierra_solo_pq): no soporta PQ**
Ofrece PQ y clásico (lo normal)	Alert o cierre	indeterminado (alerta / cierre): el fallo puede deberse al SNI, la versión, el certificado…
Cualquiera	Nada	indeterminado (sin_respuesta)

4. Validación

Prueba	Resultado
Nueva traza `casos_rechazo.pcap`: Alert 40, FIN y RST con cliente solo PQ; Alert 112 y FIN con cliente normal; sin respuesta	**Correcto** en los 6 casos.
Todas las trazas anteriores y las capturas reales de Chrome	**Sin cambios.** Solo cambia el caso real `7-estilo-roberto` (OpenSSL 3.5), que pasa de *sin_respuesta* a *rechazada / inseguro*.
40 trazas mutadas al azar, con AddressSanitizer y UBSan	**Sin errores**; JSON siempre válido.

5. Contraste con servidores reales

Método. `openssl s_client -groups X25519MLKEM768` (solo el híbrido) contra 10 servidores, mientras `tcpdump` captura; después, la captura se pasa por la sonda.

Servidor	OpenSSL (activo)	Sonda (pasivo)	
google, cloudflare, microsoft, bbva	group: X25519MLKEM768	segura / soporta_pq	✓
wikipedia.org, github.com, boe.es	alert handshake failure	rechazada / inseguro, Alert 40	✓
santander.es	unexpected eof	rechazada / inseguro, cierre FIN	✓
renfe.com	TLS 1.2 (intercambio RSA)	insegura / inseguro (version_sin_pq)	✓
uam.es	sin respuesta (30 s)	sin conexión TLS	✓

6. Hallazgos

Hallazgo	Por qué importa
uam.es tiene dos IP y solo una responde	`uam.es` resuelve a 150.244.214.237 y a 150.244.139.74. Esta vez se usó la segunda: 9 SYN en 19 s sin ninguna respuesta, así que no hubo ni conexión TCP. El 06/11 respondió la primera. Esto explica el comportamiento intermitente que vio Roberto: el resultado depende de la IP elegida, y una medida activa debería probar todas.
«Rechazada» frente a «sin respuesta»	Separarlos evita el error del resumen de Roberto, que contaba como «no soportado» a servidores que simplemente no respondían.
Dónde aplica en un despliegue pasivo	Los clientes reales casi nunca ofrecen solo PQ. En tráfico normal, un Alert sale como «indeterminado». El caso concluyente aparece en el **modo híbrido** de la patente: una sonda activa provoca con un ClientHello solo PQ y la pasiva observa la respuesta.

> **LIMITACIÓN**
> Un FIN o RST del servidor sin datos se interpreta como cierre. Si la captura perdiera los paquetes del servidor, se vería igual. En una captura completa no ocurre, pero en un despliegue con pérdidas habría que tenerlo en cuenta.

7. Siguientes pasos

- **Batería de Roberto:** lanzar su `sonda.py` con `tcpdump` capturando y comparar dominio a dominio con la sonda.
- **Otros puertos TLS** y STARTTLS; diseño de la **v2 con DTLS**; plantear el alcance de **QUIC**.

En el repositorio: `sonda/sonda.c`, `herramientas/gen_trazas.py`, `trazas/casos_rechazo.pcap`, `medidas/activa_solo_mlkem_20261111.txt` y `medidas/solo_mlkem_20261111.ndjson`.